

.....
1055 Budapest
Tel.: +36 1 391-1400
ugyfelszolgalat@naih.hu
Falk Miksa utca 9-11.
Fax: +36 1 391-1410
www.naih.hu

Case Number: NAIH-6364-1/2023 Subject: Decision initiated ex officio

in administrative proceedings

DECISION

The National Authority for Data Protection and Freedom of Information (hereinafter: Authority) has made the following decision in the ex officio initiated data protection authority proceedings concerning the data processing of BKM Budapest Public Utilities Nonprofit Ltd. (registered office: 1116 Budapest, Kalotaszeg u. 31., Company Registration No.: 01-10-042582) (hereinafter: Obligor) regarding the fulfillment of obligations set out in Regulation (EU) 2016/679 (hereinafter: General Data Protection Regulation) on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, as well as the repeal of Directive 95/46/EC, initiated on August 24, 2022.

1) The Authority establishes that the Obligor has violated the General Data Protection Regulation

-

Article 32 (1)-(2) and

-

Article 33 (3) (d).

2) In connection with the established violation, the Obligor is obliged to pay a data protection fine of 16,000,000 HUF, that is, sixteen million forints,

within 30 days from the finalization of this decision;

3) orders the publication of the final decision with the identification data of the Obligor.

The fine must be paid by bank transfer to the Authority's centralized revenue collection account (10032000-01040425-00000000 Centralized Collection Account IBAN: HU83 1003 2000 0104 0425 0000 0000). When transferring the amount, reference must be made to the NAIH-6364-1/2023 FINE number.

If the Obligor fails to comply with the payment obligation of the fine within the deadline, it is obliged to pay a late fee. The amount of the late fee is the statutory interest, which corresponds to the central bank base rate valid on the first day of the calendar half-year affected by the delay. The late fee must be paid to the Authority's centralized revenue collection account (10032000-01040425-00000000 Centralized Collection Account).

In case of non-payment of the fine and the late fee, the Authority orders the enforcement of the decision, the fine, and the late fee.

There is no administrative remedy against this decision, but it can be challenged in an administrative lawsuit with a statement of claim addressed to the Metropolitan Court within 30 days from the notification. The statement of claim must be submitted electronically to the Authority, which will forward it along with the case documents to the court. A request for a hearing must be indicated in the statement of claim. For those not fully exempt from personal fees, the court review procedure fee is 30,000 HUF, and the case is subject to the fee waiver right. Legal representation is mandatory in the proceedings before the Metropolitan Court.

REASONING

I. Established Facts

I./1. Public Interest Report, Background

(1) On August 3, 2020, a public interest report was received by the Authority via email [...], which drew the Authority's attention to the fact that several documents (complaint investigation protocols) containing personal data of natural person clients (e.g., name and address) were accessible through the following links on the website of the Obligor's predecessor, FŐTÁV Budapest District Heating Provider Ltd. (hereinafter: Predecessor).

[...]

(2) Through all the above links, pdf documents stored in the [http://www.fotav.hu/\[...\]](http://www.fotav.hu/[...]) directory were downloadable solely with possession of the link, without any prior authorization check. The reporter found this by searching for their own name in the Google search engine and found links to the above documents among the listed results, as one of them contained their name and address.

I./2. Authority Inspection Initiated in Connection with the Public Interest Report

(3) In connection with the report, the Authority initiated an inspection on October 21, 2020, under case number NAIH/2020/5917 based on the provisions of Sections 98-102 of Act CL of 2016 on General Administrative Procedure (hereinafter: Ákr.). The subject of the inspection was whether the Predecessor had complied with the obligations set out in Articles 33-34 of the General Data Protection Regulation regarding the handling of the data protection incident caused by the disclosure of personal data.

(4) To clarify the facts, the Authority, by order NAIH/2020/5917/2 on October 21, 2020, called upon the Predecessor to provide a statement and documents, to which it responded within the deadline.

(5) According to the Predecessor's response, the available documents were uploaded as part of the new website created in 2017, which are documents qualifying as public data under Section 3 (5) of Act CXII of 2011 on Informational Self-Determination and Freedom of Information (hereinafter: Infotv.), which, however, due to administrative oversight, were not properly anonymized by masking any potentially non-public personal data. The Predecessor had not previously detected the fact of the data protection incident, as no complaints had been made regarding this.

1 General Data Protection Regulation Article 4 (12): "data protection incident": a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed.

3

did not receive. At the request of the Authority, the incident was reported by the Data Controller on October 30, 2020, pursuant to Article 33(1) of the General Data Protection Regulation, which was supplemented on November 6.

(6) The protocol regarding the deletion of the data from the website was sent by the Data Controller to the Authority. According to the protocol dated October 30, 2020, the accessibility of the aforementioned documents on the website was examined by the Data Controller's data protection officer and PR and communications staff, who found that a total of 31 natural persons' 62 personal data (name, address) were involved in the reports for the first, second, and fourth quarters of 2015 and the first, third, and fourth quarters of 2016. These were stated in the protocol to be present on the website in the reports without legal basis and purpose. The Data Controller had statistics on internet accesses to the documents involved in the incident, indicating that from January 1, 2017, to November 1, 2020, they were viewed a total of 201 times. Of these, 61 views were dated to October 2020, coinciding with the initiation of the authority's investigation.

(7) To immediately terminate the violation, the protocol states that the deletion of the affected reports is necessary from the following link: [http://www.fotav.hu/\[...\]](http://www.fotav.hu/[...]). According to the protocol, this task was completed by the PR and communications staff on the aforementioned date.

(8) Furthermore, the Data Controller informed the Authority that they had amended their internal regulations, according to which, in the future, alongside built-in managerial controls, the data protection officer will also verify the documents to be published on the website, and a detailed review and inspection of the website has commenced.

(9) Later, on November 1, 2020, another public interest notification was received by the Authority from the previous notifier, drawing attention to the fact that the documents are also accessible via the link [https://docplayer.hu/\[...\]](https://docplayer.hu/[...]). In connection with this circumstance, the Authority again called upon the Data Controller to provide a statement and documents with its decision NAIH/2020/5917/8 on December 10, 2020.

(10) Based on the Data Controller's response dated December 18, 2020, they were not aware of the accessibility of the data through this website, as it is a free document-sharing portal maintained by an external provider. No customer complaints or notifications regarding the data available there were received by the Data Controller. Regarding the deletion of the link and the available documents, the Data Controller contacted the website operators. This link was no longer accessible during the Authority's subsequent re-inspection, suggesting that it was likely deleted by the website operators due to the inquiry.

(11) The Authority accepted the Data Controller's information and actions concerning the facts and handling of the data protection incident. During the authority's inspection, based on the above, no circumstances arose regarding the handling of the data protection incident by the Data Controller under Articles 33-34 of the General Data Protection Regulation that could give rise to the presumption of a violation. Therefore, on April 12, 2021, the Authority issued a decision regarding the authority's actions.

2 According to Article 33(1) of the General Data Protection Regulation, the data controller shall notify the competent supervisory authority without undue delay and, where feasible, no later than 72 hours after becoming aware of a personal data breach, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. If the notification is not made within 72 hours, reasons for the delay must be provided.

4

With the closing note of the inspection, it was established that the case does not require further action, and based on the available data, initiating further administrative proceedings is not justified under Section 101 of the Ákr.

I./3. New Public Interest Notification and Initiation of Administrative Proceedings

(12) On August 11, 2022, the Authority received a new complaint from the previous whistleblower, [...] in which they draw the Authority's attention to the fact that on the now Obligated party's website, operated as the legal successor of the predecessor, www.fotav.hu, all previously removed links and the PDF files accessible through them, containing personal data—including the whistleblower's data—are once again available. The files and personal data became accessible through the same links, with the same content and format as they were previously downloadable. The Authority re-checked the links, and indeed, they were active again through the www.fotav.hu domain. The same PDF files that were theoretically deleted according to the protocol sent by the predecessor during the administrative inspection became accessible again. This was documented by the Authority's acting case officer through the downloading of the files and the note with case number NAIH-6805-7/2022. However, the previous link from www.docplayer.hu remained inactive during the re-check, and thus the documents were not made accessible again through it.

(13) Based on the above, it was presumed that the predecessor or the Obligated party as its legal successor did not take appropriate technical and organizational measures at the time to handle the data protection incident, and as a result, the personal data became accessible again on the internet. Therefore, the Authority, in consideration of Section 60 (1) of the Infotv., initiated an official data protection authority proceeding against the Obligated party on August 24, 2022, which was

communicated under case number NAIH-6805-6/2022, and at the same time called for a statement and document provision to clarify the facts.

(14) In response to the summons, the Obligated party replied within the deadline. In its responses, the Obligated party informed the Authority that the whistleblower had already indicated via email to its customer service on August 11, 2022, that they had found their personal data again through the links reported two years ago. Due to the unexpected illness of the case officer, the complaint reached the data protection officer only on August 18, 2022. Following this, the website was immediately checked to determine whether the data sheet could be found among the data that the public authority is required to publish under the Infotv. The inspection established that the document containing the whistleblower's data was not directly accessible on the website; it could only be found with precise knowledge of the indicated links. According to the Obligated party's position, such knowledge of the link is not realistic; only someone who saved it in that form would know it accurately.

(15) The Obligated party further informed the Authority that the data protection officer immediately consulted with the IT security expert and the PR organizational unit responsible for the website after the complaint was received, revealing that although the mistakenly published reports had been deleted from the website, they were likely still retrievable from the background server, and they had not been deleted from there. This could be accessed with the exact link. The Obligated party did not previously notice that the link was live again, and as a result, the data protection incident occurred again. In 2020, the Obligated party checked whether the deletion had taken place and found it to be in order at that time.

5

(16) The Obligor also verified during the repeated investigation whether entering the name of the reporting individual into the Google search engine would yield the report that had been deleted from the website as a result. It was found that the link to the document was indeed once again available in the Google search results when searching for the name of the reporter. Therefore, during the investigation of the case and the repeated complaint by the reporter, the Obligor also wrote to Google to request the removal of the link from the search results. A few days later, following a subsequent check, it could no longer be found in the Google search results. In addition, the Obligor again deleted the document from the website and this time also from the background server. The Obligor informed the complainant about the above via email on August 23, 2022. Furthermore, an internal investigation was initiated to uncover how the personal data became accessible again on the internet.

(17) Following the above, the case officer of the Authority re-checked the relevant links on October 12, 2022, considering the contents of the Obligor's response dated September 9, 2022, registered under case number NAIH-6805-8/2022. Based on the response and the attached minutes, the Obligor deleted the data from both its website and background server. However, the links previously communicated to the Obligor were still active during the Authority's re-check on October 12, 2022, except for the first one (which also contained the complainant's data). The documents that remained accessible contained the data of several individuals, marked with names and addresses. The Authority documented the above in its record under case number NAIH-6808-10/2022 and saved the documents that were still accessible.

(18) Based on the above responses and submitted documents, further clarification of the facts was necessary in the administrative procedure; therefore, the Authority called upon the Obligor for another statement and document submission under case number NAIH-6805-6/2022 on November 24, 2022.

(19) In response to the request, the Obligor replied in a timely manner in a letter dated December 7, 2022. To the Authority's question regarding what specific technical measure is indicated by the statement that "the published reports were deleted from the website, but probably not from the background server," the Obligor responded that this means that the link to the documents was deleted from the website. Additionally, they requested the deletion of the search results and uploaded documents from access paths not operated by the Obligor (Google search and docplayer.hu).

(20) The Obligor also informed the Authority that the uploaded documents were found in a so-called

document repository on the background server serving the website www.fotav.hu. Searching among these documents is cumbersome due to the peculiarities of the system, as the directory structure of the document server fundamentally differs from the menu system of the website; file-level management and the management of the displayed access paths occur separately on the administrative interface.

(21) The Obligor informed the Authority that during the newly ordered internal investigation, it was established that the deletions documented in the previous minutes dated October 30, 2020, on the website's management interface practically only meant the deletion of links to the documents from the website's surface. The pdf format documents containing personal data physically remained in the document repository, thus, with access paths or previous search results, they could unfortunately still be found and remained accessible. After the complainant's customer service report on August 11, 2022, not only the link to the document on the website was deleted, but the document itself containing personal data was also physically deleted from the background server.

6

(22) In response to the Authority's question regarding whether measures had been taken earlier or as a result of the current incident concerning the blocking of robots indexing the Google search engine in relation to the server behind the www.fotav.hu website and the data files located there, the Obligor consistently replied: This measure is concerning in that, due to the significant number of clients and the company's activities, it is important that if, for example, a search is initiated with the Google search engine, such as for a "loading-unloading form," clients can easily find it. Therefore, according to the Obligor's position, the Google search engine should not be excluded from the document repository, and thus no such measure was implemented.

(23) The Authority also informed the Obligor that during the re-checking of relevant links on October 12, 2022, it was observed that there was only a non-active link to a document containing the complainant's data, while the others were still active and accessible, containing data of other individuals in PDF documents. In response, the Obligor informed the Authority that all similar documents, as well as the folders containing them, had now been deleted from the server (not just the links to the documents).

(24) Finally, the Authority's question to the Obligor was about what procedure it follows to anonymize personal data contained in the documents published on its website that do not fall under the concept of public data of public interest. In this regard, the Obligor informed the Authority that in 2017, its legal predecessor created a new website. At that time, the unjustified display of personal data in the examined reports was caused by negligence during the related administrative processes, as the names and addresses of the clients contained therein were not redacted, unlike in previous and later reports. The documents and reports currently uploaded to the website in large numbers—except for the data that must be published as public interest data and public data of public interest—do not contain personal data. The Obligor finally informed the Authority that it is currently working on the development of a new website.

II. Applicable Legal Provisions

According to Article 2(1) of the General Data Protection Regulation, the general data protection regulation must be applied to the data processing affected by the data protection incident.

Article 4(12) of the General Data Protection Regulation defines what constitutes a data protection incident; according to this, a "data protection incident" is a breach of security that leads to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data that is transmitted, stored, or otherwise processed.

According to Article 31 of the General Data Protection Regulation, the data controller and the data processor, as well as—if applicable—the representative of the data controller or the data processor shall cooperate with the supervisory authority in the performance of their duties, based on its inquiry.

According to Article 32 of the General Data Protection Regulation,

(1) the data controller and the data processor shall take into account the state of science and technology and the costs of implementation, as well as the nature, scope, circumstances, and purposes of the data processing, and the varying likelihood and severity of risks to the rights and freedoms of natural persons.

7

taking into account appropriate technical and organizational measures to ensure a level of data security commensurate with the risk.

(2) In determining the appropriate level of security, account must be taken of the risks arising from data processing, particularly the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data that is transmitted, stored, or otherwise processed.

According to Article 33 of the General Data Protection Regulation

(1) The data controller shall notify the supervisory authority competent under Article 55 without undue delay and, where feasible, no later than 72 hours after becoming aware of a personal data breach, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. If the notification is not made within 72 hours, it shall be accompanied by reasons for the delay.

(2) [...]

(3) The notification referred to in paragraph (1) shall at least:

a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects concerned, as well as the categories and approximate number of personal data records concerned;

b) provide the name and contact details of the data protection officer or other contact point where more information can be obtained;

c) describe the likely consequences of the personal data breach;

d) describe the measures taken or proposed by the data controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

(4) If and insofar as it is not possible to provide all the information at the same time, the information may be provided in phases without undue further delay.

(5) The data controller shall maintain a record of personal data breaches, which shall include the facts relating to the personal data breach, its effects, and the remedial measures taken. This record enables the supervisory authority to verify compliance with the requirements of this Article.

According to Article 58(2) of the General Data Protection Regulation: The supervisory authority, in exercising its corrective powers:

[...]

b) shall impose an administrative fine on the data controller or processor if the processing activities have infringed the provisions of this Regulation;

[...]

i) shall impose an administrative fine in accordance with Article 83, depending on the circumstances of each case, in addition to or instead of the measures referred to in this paragraph;

According to Article 83(1) of the General Data Protection Regulation, each supervisory authority shall ensure that administrative fines imposed under this Article for infringements of this Regulation as referred to in paragraphs (4), (5), and (6) are effective, proportionate, and dissuasive in each individual case.

According to Article 83(2) of the General Data Protection Regulation, administrative fines shall be imposed, depending on the circumstances of each case, in addition to or instead of the measures referred to in points (a) to (h) and (j) of Article 58(2). In deciding,

8

Whether an administrative fine is necessary, and when determining the amount of the administrative fine, the following must be duly considered in each case:

a) the nature, severity, and duration of the infringement, taking into account the nature, scope, or

- purpose of the data processing in question, as well as the number of data subjects affected by the infringement and the extent of the damage suffered by them;
- b) the intentional or negligent nature of the infringement;
 - c) any measures taken by the data controller or the data processor to mitigate the damage suffered by the data subjects;
 - d) the degree of responsibility of the data controller or the data processor, taking into account the technical and organizational measures implemented by them in accordance with Articles 25 and 32 of the General Data Protection Regulation;
 - e) any relevant previous infringements committed by the data controller or the data processor;
 - f) the extent of cooperation with the supervisory authority in remedying the infringement and mitigating any potentially negative effects of the infringement;
 - g) the categories of personal data affected by the infringement;
 - h) how the supervisory authority became aware of the infringement, particularly whether the data controller or the data processor reported the infringement, and if so, with what level of detail;
 - i) if any measures mentioned in Article 58(2) of the General Data Protection Regulation were previously ordered against the affected data controller or data processor in the same matter, compliance with those measures;
 - j) whether the data controller or the data processor adhered to approved codes of conduct under Article 40 of the General Data Protection Regulation or approved certification mechanisms under Article 42 of the General Data Protection Regulation; and
 - k) any other aggravating or mitigating factors relevant to the circumstances of the case, such as financial benefits gained or losses avoided as a direct or indirect consequence of the infringement.

According to Article 83(4) of the General Data Protection Regulation – in accordance with paragraph (2) – an administrative fine of up to EUR 10,000,000 or, in the case of enterprises, an amount not exceeding 2% of the total worldwide annual turnover of the preceding financial year shall be imposed; the higher amount of the two shall be applied:

- a) regarding the data controller and the data processor, the obligations specified in Articles 8, 11, 25-39, 42, and 43;

[...]

According to Section 2(2) of Act CXII of 2011 on the Right to Informational Self-Determination and on Freedom of Information (hereinafter: Infotv.), the General Data Protection Regulation shall be applied with the supplements specified therein.

Based on Section 61(1)(a) of the Infotv., the Authority may apply the legal consequences specified in the General Data Protection Regulation in connection with the data processing operations defined in Sections 2(2) and (4).

According to Section 99 of the Administrative Procedure Act (Ákr.), the authority – within the framework of its competence – monitors compliance with the provisions of the law and the fulfillment of what is stated in the enforceable decision.

According to Section 101(1)(a) of the Ákr., if the authority detects an infringement during the official inspection, it shall initiate its administrative procedure. Sections 38(3) and 60(1) of the Infotv.

9

Based on Article 38 (2) and (2a) of the Infotv., the Authority conducts an official data protection authority procedure in its capacity to enforce the right to the protection of personal data.

III. Decision

III./1. Applicability of the General Data Protection Regulation

(25) According to Article 99 (2) of the General Data Protection Regulation, the regulation must be applied from May 25, 2018. The documents affected by the data protection incident were made public on the website www.fotav.hu in the year 2017. The Obligor has maintained statistics on access to the documents since January 2017.

(26) The Obligor was informed that the documents on the website contain personal data from the Authority's decision NAIH/2020/5917/2 dated October 21, 2020. The data processing related to the incident, namely the accessibility of the documents, continued to exist even after the applicability of the General Data Protection Regulation. Therefore, the provisions of the regulation must be applied based on both the stipulations in Article 99 (2) and the provisions regarding the material scope in Article 2 (1).

(27) Furthermore, it should be noted that for the application of the provisions of the General Data Protection Regulation regarding the handling of data protection incidents, the date of knowledge of the incident is the relevant point in time, as the prescribed legal consequences are tied to this date by the regulation. From this perspective, the fact of when the accessibility of the documents affected by the incident existed on the website and when the data collected from the affected individuals appeared is not a relevant factor. Both the occurrence of the incident and the inadequate level of data security posed risks to the rights and freedoms of the affected individuals even after the regulation became applicable.

III./2. Findings regarding the handling of the data protection incident

(28) According to point 12 of Article 4 of the General Data Protection Regulation, a data protection incident is defined as a breach of security that results in the unauthorized disclosure of personal data or unauthorized access to such data. In terms of the concept, the connection to the security event is considered a key element. An event involving personal data is only classified as a data protection incident if it can be linked to some form of security breach, which is the triggering cause, and there is a causal relationship between the two. The breach of security may arise from the incomplete, inadequate, or possibly outdated security measures applied for the protection of personal data or from their complete absence.

(29) In the given case, it is important to distinguish between two separate periods: the detection of the data protection incident and the measures taken to address it. The first period of the existence of the data protection incident extends from the public disclosure of the documents containing personal data on the website www.fotav.hu (January 2017) to the first detection by the whistleblower, then by the Authority, and finally by the Obligor, and the subsequent conduct of the related authority inspection. During this period, according to the records and statements taken by the Legal Predecessor, the deletion of the affected documents (which is the...

10

In practice, this only meant the deletion of links pointing to those on the website) took place on October 30, 2020. During this period of more than three and a half years, there were a total of 201 accesses to the documents.

(30) The second period of detecting the data protection incident dates from August 11, 2022, from the second public interest notification, until the time when the Obligor permanently deleted all documents containing personal data from the background server as well. This occurred on August 18, 2022, concerning the document containing the data of the public interest notifier [...], and based on the Obligor's statements, at the latest by December 7, 2022, concerning the documents containing the personal data of other affected individuals.

(31) In the present cases, the security breach arose because the Predecessor did not implement appropriate technical and organizational measures to ensure that documents and reports qualifying as public interest data under Section 3(5) of the Infotv. related to the performance of its public duties were properly anonymized, with any potentially non-public personal data redacted. The Obligor identified the reason for this as an administrative omission. The security breach persisted despite the deletion of the links from the website, as the documents remained accessible via the internet with the appropriate reference or, for example, through a name search on Google. This was due to the fact that the documents were still stored on the background server serving the website, in the document repository. These security breaches resulted in unauthorized access to the personal data contained in the documents, thus leading to a data protection incident.

(32) Article 33 of the General Data Protection Regulation contains provisions regarding the measures to be taken in the event of a data protection incident occurring and becoming known to the data controller. According to paragraph (1), the data controller is obliged to notify the supervisory authority of the data protection incident without undue delay and, if possible, no later than 72 hours after becoming aware of the data protection incident. Notification of the incident may only be omitted if the incident is unlikely to result in a risk to the rights and freedoms of natural persons. Assessing the risks associated with the incident is the responsibility of the data controller.

(33) The Obligor first became aware of the data protection incident when it was notified by the Authority with its decision No. NAIH/2020/5917/2 dated October 21, 2020. As a result, the Obligor reported it electronically on October 30, 2020, which was supplemented electronically on November 6.

(34) Article 33(3) of the General Data Protection Regulation states what information the data controller must provide to the Authority when reporting the data protection incident. According to point d) of this paragraph, it must be stated what measures the data controller has taken or plans to take to remedy the incident, including, where appropriate, measures aimed at mitigating any adverse consequences resulting from the data protection incident.

(35) In its incident report, as well as in its responses sent to the Authority, the Obligor described the measures taken to remedy the incident and mitigate adverse consequences. Among these, it was described that after it was established that personal data appeared in the reports without a legal basis and specific purpose, their deletion was ordered.

11

which was carried out by the PR and communications staff according to the report prepared on this matter. In its response dated November 6, 2020, the Obligor also emphasized that "the part of the website where the contested personal data appeared was immediately deleted." The protocol recorded on October 30, 2020, states that "the immediate cessation of the infringement, that is, the deletion of all unnecessary and the affected reports from the website is necessary from this link: [link3]. [...] The task was completed by the PR and communications staff today at 10:30." The response and the report do not indicate that the Obligor's staff only deleted the links on the website pointing to the documents, but not the documents themselves. The Authority did not subsequently verify the unavailability of these documents and accepted the Obligor's statements regarding this matter.

(36) In addition, the Obligor also took measures regarding the deletion of documents available on www.docplayer.hu, resulting in the deletion of the documents from there. The Authority also verified the unavailability of these documents, a fact that is included in the note concluding the authority's inspection.

(37) The deletion of the documents, as a risk-reducing measure taken in response to the incident, was accepted by the Authority based on the statements made by the Obligor during the authority's inspection. The Authority deemed that, based on the information available at the time, the Obligor took appropriate measures to reduce the reported risks to the privacy of the affected individuals and handled the incident in accordance with Articles 33-34 of the General Data Protection Regulation. In light of this, the Authority concluded the inspection.

(38) Later, in connection with the second public interest notification, on August 11, 2022, the Authority learned that the documents were still accessible through the previous access routes pointing to the www.fotav.hu website. During the authority procedure initiated in this regard, the Obligor informed the Authority that although the documents involved in the incident were not directly accessible on the website, they were still available through the precise knowledge of the previous access routes and as a result of searches on Google. The reason for this is that although the links to the erroneously published reports were deleted from the website earlier, the files themselves were still retrievable on the backend server, and they were not deleted from there. Following the new notification and the results of a repeated internal investigation, the Obligor ultimately deleted all documents from the document repository on the backend server serving the website.

(39) According to Article 33(3)(d) of the General Data Protection Regulation, when reporting a data protection incident, the data controller must outline the measures taken to reduce the risks of the incident. During the Authority's inspection, the Obligor informed the Authority both in the incident report and during the clarification of the facts that it had deleted personal data processed without legal basis and purpose. The risks, therefore, in this case, that unnecessary personal data could be found publicly through the Obligor's website on the internet, can only be adequately reduced by a deletion that results in the actual data being deleted/anonymized from the affected documents and not just the references pointing to them. This is also important because the notifier, who is also an affected individual, found their own data as a result of a Google search.

3 <http://www.fotav.hu/>[...]

12

adatait. The removal of the links is therefore neither proportional to the risks nor an appropriate incident management measure.

(40) Since the inadequate incident management measure only came to the Authority's attention afterwards, it could not be assessed during the previous official inspection. The obligated party's incident management does not comply with Article 33(3)(d) of the General Data Protection Regulation, as it failed to take measures that are proportional to the risks and adequately mitigate them during the reporting and handling of the incident, and therefore provided the Authority with inadequate and misleading information about them. This is independent of whether the inadequate incident management and reporting resulted from intentional concealment or from a negligent lack of due diligence in internal procedures.

(41) Therefore, in this context, the Authority establishes that the obligated party violated Article 33(3)(d) of the General Data Protection Regulation (regarding the assessment and management of the risks of the incident) during the reporting and handling of the data protection incident that came to its attention.

III./3. Findings regarding the security of data processing

(42) Article 32 of the General Data Protection Regulation prescribes the requirements related to the security of data processing. According to paragraph (1) of this article, it is the responsibility of the data controller to implement technical and organizational measures that ensure a level of data security appropriate to the risks, taking into account the state of the science and technology and the costs of implementation. According to paragraph (2) of the above article, these security measures must guarantee, among other things, that personal data transmitted cannot be accessed unlawfully. Appropriate security measures may include, based on points (a) and (b) of paragraph (1) of the above article, the encryption of personal data and ensuring the continuous confidentiality of the systems and services used for processing personal data. The purpose of these measures is also to minimize the risks to the privacy of the affected individuals in the event of a potential data protection incident arising from a security breach.

(43) In relation to the examined data processing, it can be established that the protocols involved in the data protection incident were found in the possession of the obligated party because they were generated in connection with the performance of public duties, and therefore qualify as documents of public interest under Section 3(5) of the Infotv. However, these public interest documents included personal data (data of natural persons affected by the investigation), which do not fall under the concepts of either public interest data or publicly accessible data. Based on this, the inspection protocols therefore contain personal data that do not qualify as public interest data.

13

The Obligated Party could have only made the minutes public on its website based on its own statements if it anonymized certain personal data contained therein, for example, by deleting/redacting them.

(44) In the present case, the Obligated Party assessed and managed the risks of the examined data

processing operation by regulating in its procedural order concerning the personal data contained in the minutes that they must be anonymized before being made public.

(45) However, the above measure taken by the Obligated Party to reduce risks did not materialize, as the personal data contained in the minutes were not anonymized. According to the Obligated Party, this was due to carelessness during the administrative processes related to the redaction of the data. As a result, the internal measure taken to reduce risks (the redaction of personal data from the report) could not be effective due to this carelessness.

(46) Due to the carelessness exhibited during the administrative processes, the personal data were thus accessible on the website. As soon as the Obligated Party became aware of this from the Authority's order during the official inspection, it took steps to ensure that they would no longer be accessible, thus leading to their deletion. The Obligated Party attempted to resolve this by deleting the links to the documents on its website; however, it did not delete the documents themselves. This measure, however, was inadequate to properly guarantee the security of the personal data and to definitively eliminate the existence of the data protection incident, as the documents were still retrievable later on the internet.

(47) According to the Authority, the security of personal data would have been guaranteed if the Obligated Party had anonymized them in accordance with its own internal procedures, i.e., by redacting them from the minutes classified as public interest data. However, the Obligated Party did not act accordingly, but rather only deleted the links to the minutes from the website, which did not comply with its internal rules nor was suitable for eliminating the incident.

(48) The measures taken by the Obligated Party therefore did not ensure a level of data security proportional to the risks reported regarding the privacy of the affected individuals, which was also assessed by the Obligated Party. The mere removal of the links is not a sufficient measure to guarantee the security of the data; they should have either been properly anonymized or deleted from the server serving the website. The latter measure was only taken by the Obligated Party upon the Authority's repeated request and the initiation of the official procedure.

(49) A data security measure proportional to the risks would have been the proper anonymization of personal data or the deletion of such data from the background server. If the documents do not contain personal data, or if such data do not exist on the background server, they could not have been retrieved through the Google search engine, for example, by searching for names.

5 Infotv. § 3 (6): public data of public interest: any data not falling under the concept of public interest data, the disclosure, accessibility, or availability of which is mandated by law in the public interest;

14

(50) In light of the above, the Authority finds that the Obligated Party violated Articles 32 (1)-(2) of the General Data Protection Regulation. This is because it did not apply technical and organizational measures appropriate to the state of science and technology and proportional to the risks concerning the anonymization of the minutes, thus the personal data contained therein remained accessible on the internet.

(51) Beyond establishing the violation, the Authority does not apply any further admonition towards the Applicant, as the unlawful state has already been eliminated by the deletion of the documents in the meantime.

III./5. Legal Consequences

(52) The Authority, during the clarification of the facts, established that the Obligated Party violated the General Data Protection Regulation

- Articles 32 (1)-(2), as well as
- Article 33 (3) (d).

(53) The Authority examined ex officio whether it was justified to impose a data protection fine on the Applicant concerning the established violation. In this regard, the Authority considered all

circumstances of the case based on Article 83 (2) of the General Data Protection Regulation and Section 75/A of the Infotv.

(54) In view of this, the Authority decided, based on Section 61 (1) (a) of the Infotv., as stated in the operative part, and in this decision, it obliged the Applicant to pay a data protection fine.

(55) In determining the necessity of imposing the fine, the Authority considered the aggravating, mitigating, and other circumstances of the violations as follows:

(56) Aggravating circumstances:

- The Authority considers the data security deficiencies as a problem that persisted for a long time (between January 2017 and August 2022), and the Obligated Party was already aware of the data protection incident that occurred in this regard during the first official inspection in 2020, yet it did not carry out the appropriate risk-reducing measures. [General Data Protection Regulation Article 83 (2) (a) and (d)]
- The Authority learned of the incident and the data security deficiencies for the first time through the complaints of the affected parties and not through the data controller's incident report. [General Data Protection Regulation Article 83 (2) (h)]
- The same circumstances at the Obligated Party, namely the publication of inadequately anonymized documents, caused the same data protection incident multiple times, which is primarily the result of previous negligent incident management. The Authority assesses this as severely negligent data controller behavior. [General Data Protection Regulation Article 83 (2) (b) and (d)]

15

(57) Mitigating circumstances:

- The infringing practice did not affect a large number of data subjects; a total of 31 natural persons' names and addresses were disclosed in the public release of the records without proper anonymization. [General Data Protection Regulation Article 83(2)(a)]
- The Authority has not previously imposed a data protection fine on the Obligor for violating the General Data Protection Regulation. [General Data Protection Regulation Article 83(2)(e)]
- The personal data involved in the infringement did not pertain to aspects of the data subjects' private lives that could provide insight into more sensitive areas (e.g., special categories of data as defined in General Data Protection Regulation Article 9(1)). [General Data Protection Regulation Article 83(2)(g)]

(58) In making its decision regarding the legal consequences, the Authority did not consider the provisions of General Data Protection Regulation Article 83(2)(c), (i), (j), and (k) to be relevant.

(59) In light of the above, the Authority deems it necessary to impose a fine, considering that merely applying a warning under Section 75/A of the Infotv. was not deemed appropriate or proportional to the severity and circumstances of the infringement.

(60) The amount of the data protection fine was determined by the Authority in the exercise of its statutory discretion.

(61) In determining the amount of the fine, the Authority took into account that the infringements committed by the Obligor qualify as violations falling under the lower maximum fine category according to General Data Protection Regulation Article 83(4).

(62) The Authority considered the provisions contained in the European Data Protection Board's Guidelines 04/2022, which outline the calculation criteria for administrative fines under the General Data Protection Regulation. In this regard, the determination of the fine amount was based on the following criteria:

- The Obligor's net sales revenue for the year 2020 was 44,863,391,000 HUF, that is, forty-four billion eight hundred sixty-three million three hundred ninety-one thousand forints. The imposed fine is 0.035% of this amount.

- The Obligor's net sales revenue for the year 2021 was 62,644,955,000 HUF, that is, sixty-two billion six hundred forty-four million nine hundred fifty-five thousand forints. The imposed fine is 0.025% of this amount.
- The Obligor's net sales revenue for the year 2022 was 117,703,589,000 HUF, that is, one hundred seventeen billion seven hundred three million five hundred eighty-nine thousand forints. The imposed fine is 0.013% of this amount.
- The Authority took into account the period during which the infringement occurred, as well as publicly available management data, considering the years 2020, 2021, and 2022 at the time of the decision.
- According to General Data Protection Regulation Article 83(4), the Obligor may be subject to an administrative fine of "up to 10,000,000 EUR [static maximum fine], or in the case of enterprises, an amount not exceeding 2% of the total annual worldwide turnover of the preceding financial year [dynamic maximum fine]; the higher amount shall be imposed."
- 2% of the Obligor's revenue for 2022 is 2,354,071,780 HUF (that is, two billion three hundred fifty-four million seventy-one thousand seven hundred eighty forints), which, at the current HUF/EUR exchange rate, does not exceed the so-called static maximum fine set by the regulation, that is, an amount equivalent to 10,000,000 EUR. Since the fine must be calculated and proportioned based on the higher category applicable in this case, the Obligor may be subject to an administrative fine of up to an amount equivalent to 10,000,000 EUR.
- According to the Guidelines, for infringements that fall under the fine category of General Data Protection Regulation Article 83(4), where the static fine maximum of 10,000,000 EUR is applicable, further examination is required regarding the previous year's net revenue of the enterprise, as well as the weight of the infringement (low, medium, or significant weight).
- The Authority assessed the infringements committed, the established facts, and the aggravating and mitigating circumstances relevant to the case, deeming the infringements in this case to be of low weight.
- In this case, the Obligor's net revenue for the previous year was 117,703,589,000 HUF, that is, one hundred seventeen billion seven hundred three million five hundred eighty-nine thousand forints, which, calculated at the current HUF/EUR exchange rate, falls within the category between 250,000,000 EUR and 500,000,000 EUR as indicated by the Guidelines regarding the consideration of enterprises' management data.
- According to the Guidelines, if the enterprise's previous year's net revenue falls between 250,000,000 EUR and 500,000,000 EUR, the maximum amount of the fine that can be imposed for low-weight infringements is reduced to 1,000,000 EUR.

17

- In this case, the Obligor may be subject to a fine of up to 1,000,000 EUR, considering the above-mentioned economic data and the minor violations committed.
 - The imposed fine is therefore proportional to the severity of the violation and cannot be considered excessive; it is an extremely negligible amount compared to the economic weight of the Obligor and the financial resources available to it.
- (63) The Authority ordered the publication of the decision with the disclosure of the Obligor's identifying data based on Section 61 (2) b) of the Infotv., as it was made against a data controller providing public services (utility services).

IV.

Other Questions

- (64) The Authority's jurisdiction is defined by Section 38 (2) and (2a) of the Infotv., and its competence extends to the entire territory of the country.
- (65) Pursuant to Section 112 and Section 116 (1), as well as Section 114 (1) of the Ákr., there is a right to legal remedy against the decision through administrative litigation.

(66) The rules of administrative litigation are defined by Act I of 2017 on Administrative Litigation (hereinafter: Kp.). According to Section 12 (1) of the Kp., administrative litigation against the Authority's decision falls under the jurisdiction of the court, and based on Section 13 (3) a) aa) of the Kp., the Metropolitan Court is exclusively competent for the case. According to Section 27 (1) b) of the Kp., legal representation is mandatory in cases falling under the jurisdiction of the court. According to Section 39 (6) of the Kp., unless otherwise provided by law, the submission of the statement of claim does not have a suspensive effect on the enforcement of the administrative act.

(67) According to Section 29 (1) of the Kp. and in consideration of this, the provisions of Section 604 of Act CXXX of 2016 on Civil Procedure apply, and according to Section 9 (1) b) of Act CCXXII of 2015 on Electronic Administration and Trust Services (hereinafter: E-administration Act), the client's legal representative is obliged to maintain electronic communication.

(68) The time and place for the submission of the statement of claim are determined by Section 39 (1) of the Kp. Information regarding the possibility of requesting a hearing is based on Sections 77 (1)-(2) of the Kp. The amount of the administrative litigation fee is determined by Section 45/A (1) of Act XCIII of 1990 on Fees (hereinafter: Itv.). The party initiating the proceedings is exempt from the prior payment of the fee under Section 59 (1) and Section 62 (1) h) of the Itv.

(69) According to Section 132 of the Ákr., if the Obligor fails to comply with the obligation contained in the Authority's final decision, it is enforceable. The Authority's decision becomes final upon notification according to Section 82 (1) of the Ákr. According to Section 133 of the Ákr., the enforcement – unless otherwise provided by law or government decree – is ordered by the authority that made the decision. According to Section 134 of the Ákr., the enforcement – unless otherwise provided by law, government decree, or a local government regulation in a local government authority matter – is carried out by the state tax authority. According to Section 60 (7) of the Infotv., regarding the obligation to perform a specific act, to behave in a certain way, to tolerate, or to cease a certain behavior as stated in the Authority's decision, the enforcement of the decision is carried out by the Authority.

Budapest, June 23, 2023

Dr. habil. Attila Péterfalvi
President, Professor Emeritus